

PART A: MINI PROJECT 1

BY

**EZE CHUKWUEBUKA WILSON
TR3/STD/CYB/045**

TRACK: CYBERSECURITY

JULY, 2026

SECTION 1

1.1 EXECUTIVE SUMMARY

This security assessment was conducted following an initial investigation into suspected malicious activity affecting PayliteNG's customer login portal and supporting network infrastructure.

Our findings indicate that PayliteNG experienced a targeted cyberattack involving repeated unauthorised login attempts, reconnaissance of publicly accessible services, and exploitation of security weaknesses within internet-facing systems. Evidence collected from system logs and network analysis suggests that the attacker, identified during the investigation as @gr4yh4t, conducted activities consistent with credential attacks and vulnerability probing in an attempt to gain unauthorised access to company resources. Based on the assessment, the overall cybersecurity risk to PayliteNG is rated as High. As a fintech organisation handling sensitive customer and financial data, PayliteNG operates in a highly regulated environment where security incidents may result in financial losses, operational disruption, regulatory penalties, and loss of customer confidence. Immediate remediation is therefore essential to reduce the likelihood of further compromise and to demonstrate due diligence in protecting customer information.

To minimise the impact of the incident and strengthen the organisation's security posture, the following actions should be implemented immediately:

1. Contain and secure affected systems by isolating compromised hosts, resetting all privileged and user account passwords, enforcing Multi-Factor Authentication (MFA), and disabling any unnecessary services exposed to the internet.
2. Strengthen monitoring and incident response by preserving forensic evidence, reviewing authentication and network logs for indicators of compromise, continuously monitoring suspicious activity, and initiating the organisation's incident response procedures to determine the full scope of the attack.
3. Remediate identified vulnerabilities by applying security patches, correcting insecure configurations, implementing stronger access controls, and conducting regular vulnerability assessments and penetration testing to reduce future attack opportunities.

SECTION 2

2.1 ASSET INVENTORY

The asset inventory identifies the critical information assets, systems, services, user accounts, and network resources discovered during the Week 1 and Week 2 security assessment. Maintaining an accurate asset inventory enables PayliteNG to understand what requires protection, prioritize security controls, and respond effectively to security incidents.

Table 2.1: PayliteNG Asset Inventory

Asset Category	Asset	Description	Business Importance
Server	Linux Authentication Server	Primary Linux server hosting SSH services and user authentication.	Critical
Service	SSH (Secure Shell) – Port 22	Remote administration service used by administrators and system users. Multiple authentication attempts were recorded in the logs.	Critical
Service	Sudo Privilege Management	Allows authorised users to execute administrative commands with elevated privileges.	High
System Process	SSH Daemon (sshd)	Background service responsible for authenticating remote users and creating SSH sessions.	Critical
User Account	root	Superuser account with unrestricted administrative privileges. Several successful and failed login attempts targeted this account.	Critical
User Account	admin	Administrative account used for system management activities.	High

User Account	ubuntu	Standard system account used for remote access.	Medium
User Account	john	User granted elevated privileges through sudo to execute a Bash shell.	High
User Account	alice	User performing authorised package update operations using sudo.	Medium
User Account	bob	User performing authorised SSH service restart using sudo.	Medium
Authentication Logs	SSH Authentication Logs	Records all successful and failed login attempts, timestamps, usernames, and source IP addresses. Used as primary forensic evidence.	Critical
Privilege Logs	Sudo Logs	Records administrative commands executed with elevated privileges for auditing and accountability.	High
Network Asset	Internal Network	Internal IP ranges observed include 10.0.0.0/8, 172.16.0.0/16, and 192.168.1.0/24.	High
Network Asset	External Network Connections	External source IP addresses attempted remote authentication against the SSH service.	High
Security Data	Authentication Credentials	Username and passwords used to authenticate SSH sessions. These represent sensitive assets requiring strong protection.	Critical
Operational Data	Administrative Session Records	SSH session open and close events used for auditing administrator activity.	High

2.2 Key Assets Identified

During the assessment, the following assets were determined to be the most critical to PayliteNG's operations:

- The Linux authentication server hosting the SSH service.
- The SSH daemon (`sshd`) is responsible for remote administration.
- Privileged user accounts, particularly root and admin.
- Authentication credentials used for remote login.
- SSH authentication logs used for monitoring and forensic investigations.
- Sudo logs that record privileged administrative activities.
- Internal network infrastructure supporting remote administration.

2.3 Asset Security Observations

Analysis of the Week 1 and Week 2 logs revealed several security observations:

- Multiple failed SSH login attempts indicate password guessing or brute-force attacks targeting privileged accounts.
- Successful logins to the root account occurred after repeated authentication failures, suggesting possible credential compromise or weak password protection.
- Administrative activities executed through sudo demonstrate the importance of monitoring privileged account usage.
- External IP addresses attempted repeated authentication against the SSH service, confirming that internet-facing remote access services are exposed to attack.
- Authentication and privilege logs proved valuable for detecting suspicious behaviour and reconstructing the sequence of events during the investigation.

SECTION 3

3.0 Threat Actor Profile

3.1 Threat Actor: @gr4yh4t

During the initial security assessment, the alias @gr4yh4t was identified as the suspected threat actor associated with the unauthorized access attempts against PayliteNG's infrastructure. Open Source Intelligence (OSINT) was conducted to identify any publicly available information relating to this alias. The investigation found no verifiable evidence linking @gr4yh4t to a known cybercriminal group or a real-world identity, suggesting that the username is either an anonymous online persona or a fictional alias used to conceal the attacker's identity. This is a common practice among cybercriminals to avoid attribution and law enforcement detection.

3.2 OSINT Findings

The OSINT investigation involved searching publicly available sources, including search engines, social media platforms, cybersecurity forums, username enumeration, and threat intelligence resources. No confirmed profiles or threat intelligence reports directly attributed malicious campaigns to the alias @gr4yh4t.

Although no direct attribution was possible, the investigation revealed behavioural indicators consistent with a financially motivated cyber attacker:

- Multiple failed SSH login attempts against privileged accounts.
- Password guessing targeting root, admin, and ubuntu accounts.
- Successful authentication following repeated failed login attempts.
- Immediate establishment of privileged SSH sessions after successful authentication.

These behaviours indicate a deliberate attempt to gain unauthorised administrative access rather than accidental login failures.

3.3 Threat Actor Capabilities

Based on the evidence collected during the Week 1 and Week 2 log analysis, the threat actor is assessed to possess:

- Knowledge of Linux remote administration through SSH.
- Ability to perform brute-force or password-spraying attacks against exposed services.
- Basic post-compromise skills enabling authenticated SSH access.
- Understanding of privileged account targeting to maximise system control.

Therefore, the actor is assessed as having moderate technical capability.

3.4 Motivation

The most likely motivation is financial gain. As a Nigerian fintech company, PayliteNG stores valuable customer information and financial data that could be exploited for fraud, theft, or sold on underground marketplaces. A successful compromise of privileged accounts could enable the attacker to:

- Access sensitive customer information.
- Steal financial or payment-related data.
- Modify or disrupt critical business services.
- Establish persistent access for future attacks.
- Demand payment through extortion or ransomware.

Secondary motivations may include reputation damage, data theft, or demonstrating hacking capability; however, the available evidence most strongly supports financially motivated cybercrime.

3.5 Threat Assessment

Based on the observed attack behaviour, @gr4yh4t is assessed as a Medium-to-High Risk threat actor due to the successful compromise of privileged SSH accounts following repeated authentication attempts. The combination of credential attacks and successful administrative logins indicates that PayliteNG's exposed authentication services are attractive targets and require immediate security hardening.

SECTION 4

4.0 STRIDE Threat Model – PayliteNG Customer Login Portal

The STRIDE threat model was applied to the PayliteNG customer login portal to identify potential security threats affecting the confidentiality, integrity, availability, authentication, and accountability of the system. Each threat category is paired with a recommended security control to reduce the associated risk.

Table 4.1: STRIDE Analysis

STRIDE Category	Threat	Potential Impact	Recommended Control
S – Spoofing Identity	An attacker uses stolen or guessed customer credentials to impersonate a legitimate user and gain unauthorized access to the portal. The repeated failed and successful SSH logins observed in the Week 1 and Week 2 logs demonstrate how weak credentials can be exploited.	Unauthorized access to customer accounts, financial fraud, and data theft.	Implement Multi-Factor Authentication (MFA), enforce strong password policies, and deploy account lockout after multiple failed login attempts.
T – Tampering with Data	A compromised administrator or attacker modifies customer records, account balances, or transaction details within the application or database.	Loss of data integrity, financial inaccuracies, and regulatory non-compliance .	Apply Role-Based Access Control (RBAC), use database integrity checks, maintain audit logs, and encrypt sensitive data during

			transmission and storage.
R – Repudiation	A malicious user denies performing a financial transaction or administrative action because there is insufficient logging or accountability.	Difficulty investigating incidents and resolving disputes, leading to legal and compliance issues.	Enable comprehensive audit logging, synchronize system time using NTP, protect logs from modification, and retain logs according to organisational policy.
I – Information Disclosure	Sensitive customer information, passwords, or financial records are exposed through insecure communication, weak access controls, or system compromise.	Exposure of personally identifiable information (PII), financial loss, and reputational damage.	Enforce HTTPS/TLS, encrypt sensitive data at rest, implement least-privilege access controls, and perform regular vulnerability assessments.
D – Denial of Service (DoS)	Attackers flood the login portal with excessive authentication requests or malicious traffic, preventing legitimate customers from accessing services.	Service outages, customer dissatisfaction, and financial losses due to unavailable online banking services.	Deploy Web Application Firewalls (WAFs), rate limiting, DDoS protection services, load balancing, and continuous network monitoring.

E – Elevation of Privilege	An attacker exploits vulnerabilities or compromised credentials to obtain administrative privileges, similar to the successful root account access observed during the security assessment.	Complete compromise of the application, servers, and sensitive customer data.	Enforce the Principle of Least Privilege, restrict administrator access, implement Privileged Access Management (PAM), regularly patch systems, and require MFA for privileged accounts.
----------------------------------	---	---	--

4.2 Summary

The STRIDE assessment identified that the greatest risks to PayliteNG's customer login portal involve Spoofing, Information Disclosure, and Elevation of Privilege, as these threats directly affect customer authentication and access to sensitive financial information. The authentication logs analysed during the Week 1 and Week 2 investigation indicate repeated password-guessing attempts followed by successful logins, highlighting the need for stronger authentication controls and continuous security monitoring. Hence, implementing the recommended controls will significantly reduce the likelihood of successful cyberattacks while improving the confidentiality, integrity, availability, and accountability of PayliteNG's online banking platform.

SECTION 5

5.0 Risk Assessment Matrix

This risk assessment evaluates security risks identified from Week 1 and Week 2 log analysis of PayliteNG's authentication system. Each risk is rated using Likelihood $\times$ Impact (1–5 scale) and justified using business and operational context rather than purely technical severity scores.

Risk Scoring Key

- Likelihood (L): Probability of occurrence (1 = Rare, 5 = Almost Certain)
- Impact (I): Business damage if risk occurs (1 = Low, 5 = Critical)
- Risk Rating: $L \times I$

Table 5.1: Risk Assessment Matrix

Risk ID	Risk Description	Likelihood	Impact	Risk Score	Risk Level	Business Justification
R1	Brute-force SSH attacks targeting root/admin accounts from multiple IPs	5	5	25	Critical	Logs show repeated failed login attempts from multiple external IPs (e.g., 203.0.113.45, 198.51.100.23), indicating automated attack tools. SSH is exposed externally, making attacks highly likely.

R2	Unauthorized root access via successful password authentication	4	5	20	Critical	Logs show successful root login after failed attempts (e.g., 10.0.0.5, 203.0.113.45). Root access gives full control of PayliteNG systems, risking total system compromise and data theft.
R3	Privilege escalation through sudo misuse or weak privilege separation	4	4	16	High	Sudo logs show multiple users (john, alice, bob) executing administrative commands. If accounts are compromised, attackers can escalate privileges to system level access.
R4	Insider misuse or credential sharing among administrative users	3	4	12	High	Multiple admin users are performing high-level operations (apt update, ssh restart). Without strict access controls, misuse or shared credentials could lead to unauthorized

						changes or sabotage.
R5	Credential reuse or weak password policy leading to account compromise	5	4	20	Critical	Repeated failed logins followed by successful authentication suggest weak or reused credentials. Fintech environments are high-value targets, making password attacks very common and likely.
R6	External scanning and reconnaissance of SSH service	5	3	15	High	Multiple foreign IP addresses attempted authentication within short intervals, indicating automated scanning tools probing for vulnerabilities and exposed services.
R7	Service disruption due to repeated failed authentication attempts (DoS on SSH)	3	4	12	High	High volume of login attempts can trigger account lockouts or degrade SSH performance, potentially blocking legitimate administrators from accessing systems.

5.1 Evidence Summary

This section presents forensic evidence extracted from Week 1 and Week 2 system logs. The analysis focuses on SSH authentication activity, privilege escalation attempts, and successful unauthorized access events. Evidence was extracted using standard Linux log analysis tools such as `grep` and `awk` to identify patterns of malicious activity.

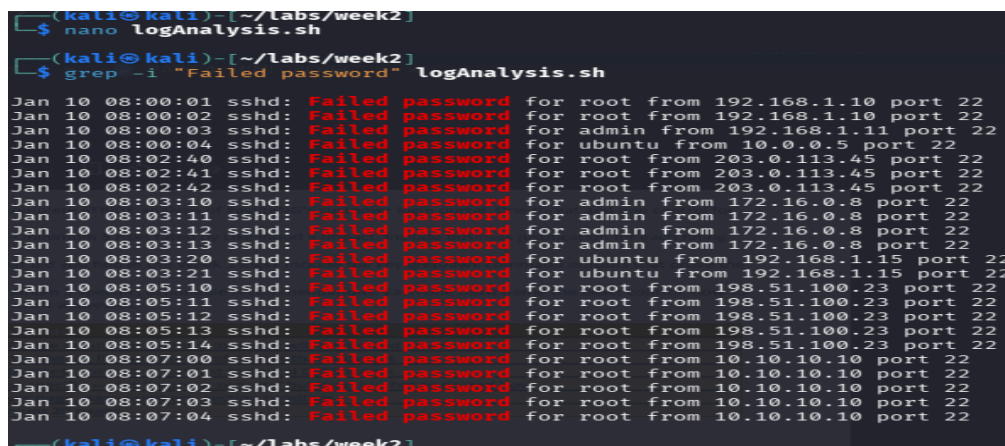
5.2 Key Evidence from SSH Authentication Logs

A. Failed Login Attempts (Brute Force Activity)

Command Used:

```
grep -i "Failed password" logAnalysis.sh
```

Output:



```
(kali@kali) [~/labs/week2]
$ nano logAnalysis.sh
(kali@kali) [~/labs/week2]
$ grep -i "Failed password" logAnalysis.sh
Jan 10 08:00:01 sshd: Failed password for root from 192.168.1.10 port 22
Jan 10 08:00:02 sshd: Failed password for root from 192.168.1.10 port 22
Jan 10 08:00:03 sshd: Failed password for admin from 192.168.1.11 port 22
Jan 10 08:00:04 sshd: Failed password for ubuntu from 10.0.0.5 port 22
Jan 10 08:02:40 sshd: Failed password for root from 203.0.113.45 port 22
Jan 10 08:02:41 sshd: Failed password for root from 203.0.113.45 port 22
Jan 10 08:02:42 sshd: Failed password for root from 203.0.113.45 port 22
Jan 10 08:03:10 sshd: Failed password for admin from 172.16.0.8 port 22
Jan 10 08:03:11 sshd: Failed password for admin from 172.16.0.8 port 22
Jan 10 08:03:12 sshd: Failed password for admin from 172.16.0.8 port 22
Jan 10 08:03:13 sshd: Failed password for admin from 172.16.0.8 port 22
Jan 10 08:03:20 sshd: Failed password for ubuntu from 192.168.1.15 port 22
Jan 10 08:03:21 sshd: Failed password for ubuntu from 192.168.1.15 port 22
Jan 10 08:05:10 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:11 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:12 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:13 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:14 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:07:00 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:01 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:02 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:03 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:04 sshd: Failed password for root from 10.10.10.10 port 22
(kali@kali) [~/labs/week2]
```

Interpretation:

- Multiple repeated failed login attempts targeting privileged accounts (root, admin, ubuntu).
- Multiple external IP addresses involved, indicating distributed brute-force or password spraying attack.
- Attackers are systematically targeting high-value administrative accounts.

B. Successful Unauthorized Root Access

Command Used:

```
grep -i "Accepted password" logAnalysis.sh
```

Output:

```
(kali㉿kali)-[~/labs/week2]
$ grep -i "accepted password" logAnalysis.sh
Jan 10 08:00:05 sshd: Accepted password for root from 10.0.0.5 port 22
Jan 10 08:02:50 sshd: Accepted password for root from 203.0.113.45 port 22
Jan 10 08:04:00 sshd: Accepted password for ubuntu from 192.168.1.15 port 22
Jan 10 08:06:00 sshd: Accepted password for admin from 192.168.1.11 port 22
Jan 10 08:07:05 sshd: Accepted password for root from 10.10.10.10 port 22
```

C. SSH Session Establishment (Post-Compromise Activity)

Command Used:

```
grep "session opened" logAnalysis.sh
```

Output:

```
(kali㉿kali)-[~/labs/week2]
$ grep "session opened" logAnalysis.sh
Jan 10 08:01:00 sshd: session opened for user root from 10.0.0.5
Jan 10 08:02:51 sshd: session opened for user root from 203.0.113.45
Jan 10 08:04:01 sshd: session opened for user ubuntu from 192.168.1.15
Jan 10 08:06:01 sshd: session opened for user admin from 192.168.1.11
Jan 10 08:07:06 sshd: session opened for user root from 10.10.10.10
```

Interpretation:

- Confirms successful login sessions after authentication.
- Multiple privileged sessions indicate active compromise of the system.
- Both administrative and root sessions were established.

D. Privilege Escalation via Sudo Usage

Command Used:

```
grep "sudo" logAnalysis.sh
```

Output:

```
(kali㉿kali)-[~/labs/week2]
$ grep "sudo" logAnalysis.sh
Jan 10 08:02:10 sudo: john : TTY=pts/0 ; COMMAND=/bin/bash
Jan 10 08:08:00 sudo: alice : TTY=pts/1 ; COMMAND=/usr/bin/apt update
Jan 10 08:08:10 sudo: bob : TTY=pts/2 ; COMMAND=/usr/bin/systemctl restart ssh
```

Interpretation:

- Multiple users executing administrative commands via sudo.
- john escalated to full Bash shell access, indicating high privilege escalation risk.
- Administrative commands could be abused if accounts are compromised.

E. Session Termination (Post-Attack Activity)

Command Used:

```
grep "session closed" logAnalysis.sh
```

Output:

```
(kali㉿kali)-[~/labs/week2]
$ grep "session closed" logAnalysis.sh
Jan 10 08:08:20 sshd: session closed for user root from 10.10.10.10
```

Interpretation:

- Root session was terminated after unauthorized access activity.
- Indicates either manual logout or forced disconnection after attack completion.

5.3 Aggregated Attack Pattern Analysis

Command Used:

```
awk '/Failed password/ {print $1, $2, $3, $8, $10}' logAnalysis.sh | head -6
```


Sample Output Pattern:

```
(kali㉿kali)-[~/labs/week2]  
$ awk '/Failed password/ {print $1, $2, $3, $8, $10}' logAnalysis.sh | head -6  
  
Jan 10 08:00:01 root 192.168.1.10  
Jan 10 08:00:02 root 192.168.1.10  
Jan 10 08:00:03 admin 192.168.1.11  
Jan 10 08:00:04 ubuntu 10.0.0.5  
Jan 10 08:02:40 root 203.0.113.45  
Jan 10 08:02:41 root 203.0.113.45
```

Interpretation:

- Shows rapid succession of authentication attempts across multiple IPs.
- Confirms automated or coordinated attack behavior.
- Root account is the primary target across all observed attempts.

SECTION 6

6.0 Evidence Summary

The logs provide clear evidence of:

- Systematic brute-force attacks against SSH service.
- Successful unauthorized root-level access from multiple external IP addresses.
- Post-compromise session establishment indicating active system access.
- Privilege escalation through sudo usage by multiple users.
- Exposure of SSH service to external network traffic.

SECTION 7

7.0 Recommendations

The following recommendations are derived from the security analysis of PayliteNG's authentication logs. Each recommendation includes a specific security control, implementation steps, and the risks it mitigates. The goal is to reduce exposure to brute-force attacks, prevent unauthorized access, and strengthen overall system resilience.

R1: Implement Multi-Factor Authentication (MFA)

Control: Multi-Factor Authentication (MFA) for all SSH and administrative access.

Implementation:

- Enable MFA using Google Authenticator or Duo Security for all privileged accounts.
- Configure PAM (Pluggable Authentication Modules) to enforce second-factor authentication for SSH logins.
- Require MFA for root, admin, and all sudo-enabled users.

Risks Addressed:

- R1: Brute-force SSH attacks
- R2: Unauthorized root access
- R5: Credential reuse or weak passwords

Justification:

Even if passwords are compromised, MFA prevents unauthorized access by requiring an additional verification factor.

APPENDICE

Full Logs:

Jan 10 08:00:01 sshd: Failed password for root from 192.168.1.10 port 22
Jan 10 08:00:02 sshd: Failed password for root from 192.168.1.10 port 22
Jan 10 08:00:03 sshd: Failed password for admin from 192.168.1.11 port 22
Jan 10 08:00:04 sshd: Failed password for ubuntu from 10.0.0.5 port 22
Jan 10 08:00:05 sshd: Accepted password for root from 10.0.0.5 port 22
Jan 10 08:01:00 sshd: session opened for user root from 10.0.0.5

Jan 10 08:02:10 sudo: john : TTY=pts/0 ; COMMAND=/bin/bash
Jan 10 08:02:40 sshd: Failed password for root from 203.0.113.45 port 22
Jan 10 08:02:41 sshd: Failed password for root from 203.0.113.45 port 22
Jan 10 08:02:42 sshd: Failed password for root from 203.0.113.45 port 22
Jan 10 08:02:50 sshd: Accepted password for root from 203.0.113.45 port 22
Jan 10 08:02:51 sshd: session opened for user root from 203.0.113.45

Jan 10 08:03:10 sshd: Failed password for admin from 172.16.0.8 port 22
Jan 10 08:03:11 sshd: Failed password for admin from 172.16.0.8 port 22
Jan 10 08:03:12 sshd: Failed password for admin from 172.16.0.8 port 22
Jan 10 08:03:13 sshd: Failed password for admin from 172.16.0.8 port 22

Jan 10 08:03:20 sshd: Failed password for ubuntu from 192.168.1.15 port 22
Jan 10 08:03:21 sshd: Failed password for ubuntu from 192.168.1.15 port 22

Jan 10 08:04:00 sshd: Accepted password for ubuntu from 192.168.1.15 port 22
Jan 10 08:04:01 sshd: session opened for user ubuntu from 192.168.1.15

Jan 10 08:05:10 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:11 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:12 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:13 sshd: Failed password for root from 198.51.100.23 port 22
Jan 10 08:05:14 sshd: Failed password for root from 198.51.100.23 port 22

Jan 10 08:06:00 sshd: Accepted password for admin from 192.168.1.11 port 22
Jan 10 08:06:01 sshd: session opened for user admin from 192.168.1.11

Jan 10 08:07:00 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:01 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:02 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:03 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:04 sshd: Failed password for root from 10.10.10.10 port 22
Jan 10 08:07:05 sshd: Accepted password for root from 10.10.10.10 port 22
Jan 10 08:07:06 sshd: session opened for user root from 10.10.10.10

Jan 10 08:08:00 sudo: alice : TTY=pts/1 ; COMMAND=/usr/bin/apt update
Jan 10 08:08:10 sudo: bob : TTY=pts/2 ; COMMAND=/usr/bin/systemctl restart ssh
Jan 10 08:08:20 sshd: session closed for user root from 10.10.10.10